

Informe VAST.

VAST no es un “marco nacional” de ciberseguridad, sino una metodología de *modelado de amenazas* (Visual, Agile, Simple Threat) pensada para escalar en grandes organizaciones y entornos DevSecOps, sobre la que podemos construir indicadores a nivel país enlazando con índices nacionales (como el NCSI) y marcos cuantitativos (NIST CRS, VaR, métricas nacionales tipo “dashboard”).¹²³⁴⁵

1. Qué es VAST y qué mide (de verdad)

- VAST es una metodología de modelado de amenazas diseñada para integrarse en el ciclo de vida de desarrollo (SDLC) y en pipelines CI/CD, con tres pilares: automatización, integración y colaboración.²⁶⁷¹
- Utiliza dos tipos de modelos:
Modelos de amenazas de aplicación, basados en diagramas de flujo de procesos, para identificar riesgos arquitectónicos en el software.¹²
Modelos de amenazas operacionales, basados en diagramas de flujo de datos (DFD), para ver los sistemas desde la perspectiva del atacante y de la infraestructura.⁸¹
- VAST no impone un sistema único de puntuación, pero se apoya en:
Escala de severidad (a menudo derivadas de CVSS o métricas propietarias) para priorizar amenazas.⁹¹⁰
KPIs de riesgo y cumplimiento que se pueden alinear con marcos como NIST SP 800-53 y con herramientas de puntuación de riesgo (CRS, VaR, etc.).¹¹¹²⁵
- Modelos de amenazas de aplicación, basados en diagramas de flujo de procesos, para identificar riesgos arquitectónicos en el software.¹²
- Modelos de amenazas operacionales, basados en diagramas de flujo de datos (DFD), para ver los sistemas desde la perspectiva del atacante y de la infraestructura.⁸¹
- Escalas de severidad (a menudo derivadas de CVSS o métricas propietarias) para priorizar amenazas.⁹¹⁰
- KPIs de riesgo y cumplimiento que se pueden alinear con marcos como NIST SP 800-53 y con herramientas de puntuación de riesgo (CRS, VaR, etc.).¹¹¹²⁵

1 <https://www.huntress.com/cybersecurity-101/topic/vast-threat-modeling>

2 <https://threatmodeler.com/glossary/vast-threat-methodology/>

3 <https://ncsi.ega.ee/indicators/>

4 <https://www.aspendigital.org/blog/national-cyber-metrics/>

5 [https://csrc.nist.gov/CSRC/media/Presentations/nist-cyber-risk-scoring-crs-program-overview/images-media/NIST Cyber Risk Scoring \(CRS\) - Program Overview.pdf](https://csrc.nist.gov/CSRC/media/Presentations/nist-cyber-risk-scoring-crs-program-overview/images-media/NIST%20Cyber%20Risk%20Scoring%20(CRS)%20-%20Program%20Overview.pdf)

Ejemplo ilustrativo: una plataforma como ThreatModeler implementa VAST para generar automáticamente modelos, identificar amenazas y asignarles puntuaciones basadas en impacto sobre activos y datos, produciendo informes de riesgo consumibles por ejecutivos y equipos técnicos.⁶⁷⁸

2. Tipología de indicadores VAST (nivel organización)

2.1. Indicadores de cobertura y calidad del modelado

- Porcentaje de aplicaciones críticas con modelo de amenazas VAST actualizado (vs. inventario total).
- Porcentaje de flujos de datos externos (APIs, terceros, nube) modelados en diagramas operacionales.
- Densidad de amenazas identificadas por componente o por flujo (amenazas por microservicio, por API, por “sistema lógico”).²⁸¹
- Ratio amenazas “aceptadas” vs. mitigadas, por dominio (identidad, red, datos, cadena de suministro).

Estos indicadores se usan típicamente en programas de DevSecOps maduros, donde el modelado de amenazas es continuo y automatizado.⁹¹⁰¹¹¹²

2.2. Indicadores de riesgo técnico (ligados a VAST)

- Severidad media ponderada de amenazas abiertas, basada en escalas tipo CVSS o scoring propio (baja-crítica).⁹¹⁰
- Distribución de amenazas por fase de kill chain (reconocimiento, acceso inicial, movimiento lateral, exfiltración) para priorizar controles.¹⁴
- Número de amenazas asociadas a vulnerabilidades explotadas activamente (cruce con inteligencia de amenazas y métricas como VPR de Tenable).¹⁵¹⁰

6 <https://threat-modeling.com/what-is-threat-modeling/>

7 <https://www.infosecinstitute.com/resources/management-compliance-auditing/understanding-role-threat-modeling-risk-management/>

8 <https://threatmodeler.com/glossary/vast-threat-methodology/>

9 <https://www.securitycompass.com/blog/threat-modeling-in-agile-development/>

10 <https://www.infosecinstitute.com/resources/management-compliance-auditing/understanding-role-threat-modeling-risk-management/>

11 <https://www.aikido.dev/blog/aikido-threat-modeling>

12 <https://www.huntress.com/cybersecurity-101/topic/vast-threat-modeling>

2.3. Indicadores de eficacia de mitigación

- Tiempo medio desde identificación de amenaza VAST hasta definición de control (MTTD de diseño) y hasta despliegue efectivo (MTTR de mitigación).
- Porcentaje de amenazas con controles automatizados (por ejemplo, políticas de IAM/PAM, reglas en WAF, segmentación Zero Trust) frente a controles puramente procedimentales.¹²
- Porcentaje de amenazas reabiertas tras cambios en arquitectura (regresiones de seguridad por releases ágiles).¹³¹

3. Escalar VAST a nivel nacional: qué significa en España

VAST, por sí solo, no es un marco de ciberseguridad nacional; para llevarlo al nivel “territorial España” hay que anclarlo en:

- La gobernanza nacional (Plan Nacional de Ciberseguridad, CNC, transposición NIS2, etc.).¹⁶¹⁷¹⁸
- Índices comparativos globales con indicadores claros (NCIS, métricas tipo “national cyber dashboard”).³⁴
- Esquemas de puntuación y riesgo cuantitativo (NIST Cyber Risk Scoring, pérdidas esperadas, VaR de ciber).¹²⁵

3.1. Referencias institucionales clave en España

- El Gobierno español ha aprobado un paquete de refuerzo de ciberseguridad y ciberdefensa (más de 1.157 M€) para mejorar la protección de información, servicios e infraestructuras críticas; en 2024 se detectaron más de 100.000 ciberataques, con un incidente muy grave cada tres días.¹⁷¹⁶
- Se ha creado un nuevo Centro Nacional de Ciberseguridad (CNC) como autoridad nacional para dirigir y coordinar la ciberseguridad en línea con NIS2, dependiente de la Presidencia del Gobierno.¹⁷
- El CCN-CERT, dependiente del Centro Criptológico Nacional, continúa como centro de alerta nacional y autoridad en protección de la información clasificada, coordinando incidentes en todas las administraciones públicas.¹⁸

Estos elementos proporcionan la capa de gobernanza sobre la cual un enfoque “VAST-like” podría alimentar indicadores estratégicos a escala país.

3.2. Indicadores nacionales inspirados en VAST

Tomando como inspiración VAST (modelos de amenazas de aplicación y operación) y marcos como el National Cyber Security Index (NCIS) y las propuestas de “national cyber metrics dashboards”, podemos definir categorías de indicadores nacionales:¹³¹⁴¹⁵

¹³ <https://www.aspendigital.org/blog/national-cyber-metrics/>

¹⁴ <https://ncsi.ega.ee/indicators/>

¹⁵ <https://www.huntress.com/cybersecurity-101/topic/vast-threat-modeling>

1. Modelado y cobertura de amenazas críticas:

Porcentaje de servicios esenciales y operadores de infraestructuras críticas con modelos de amenazas formales en vigor (VAST u otra metodología estructurada tipo STRIDE, PASTA, etc.).193

Porcentaje de flujos transfronterizos de datos (sanidad, energía, finanzas, defensa) con análisis de amenazas actualizado, incluyendo nube y terceros.

2. Riesgo y exposición agregada:

Número de incidentes significativos por periodo, con desglose por sector y criticidad (alineado con propuestas como las de Aspen Digital).164

Tiempo medio para contener actividad maliciosa (MTTC) a nivel nacional, agregando datos de CNC, CCN-CERT e INCIBE.184

Pérdida económica total estimada por ciberincidentes al año, y probabilidad de exceder ciertos umbrales de pérdida (VaR nacional).412

3. Vulnerabilidades y errores persistentes:

Porcentaje de vulnerabilidades actualmente explotadas en el país que tienen más de un año (métrica 1 del dashboard Aspen).4

Porcentaje de sistemas críticos con vulnerabilidades explotadas activamente sin parchear, cruzando con datos de herramientas de riesgo como NIST CRS o soluciones comerciales (ACR, VPR).515

4. Capacidad y talento:

Porcentaje de puestos de ciber no cubiertos en sectores críticos, uno de los cinco indicadores propuestos por Aspen Digital.4

Indicadores nacionales de talento digital en TIC y ciberseguridad (por ejemplo, informes sobre empleabilidad y talento digital en España).2021

5. Gobernanza y estrategia:

Existencia y grado de implementación del Plan Nacional de Ciberseguridad y su plan de acción (con KPIs por medida).316

Nivel de centralización y claridad de la responsabilidad política de la ciberseguridad (liderazgo de alto nivel, ministerios responsables, CNC).173

- Porcentaje de servicios esenciales y operadores de infraestructuras críticas con modelos de amenazas formales en vigor (VAST u otra metodología estructurada tipo STRIDE, PASTA, etc.).193
- Porcentaje de flujos transfronterizos de datos (sanidad, energía, finanzas, defensa) con análisis de amenazas actualizado, incluyendo nube y terceros.
- Número de incidentes significativos por periodo, con desglose por sector y criticidad (alineado con propuestas como las de Aspen Digital).164
- Tiempo medio para contener actividad maliciosa (MTTC) a nivel nacional, agregando datos de CNC, CCN-CERT e INCIBE.184
- Pérdida económica total estimada por ciberincidentes al año, y probabilidad de exceder ciertos umbrales de pérdida (VaR nacional).412
- Porcentaje de vulnerabilidades actualmente explotadas en el país que tienen más de un año (métrica 1 del dashboard Aspen).4
- Porcentaje de sistemas críticos con vulnerabilidades explotadas activamente sin parchear, cruzando con datos de herramientas de riesgo como NIST CRS o soluciones comerciales (ACR, VPR).515
- Porcentaje de puestos de ciber no cubiertos en sectores críticos, uno de los cinco indicadores propuestos por Aspen Digital.4
- Indicadores nacionales de talento digital en TIC y ciberseguridad (por ejemplo, informes sobre empleabilidad y talento digital en España).2021
- Existencia y grado de implementación del Plan Nacional de Ciberseguridad y su plan de acción (con KPIs por medida).316
- Nivel de centralización y claridad de la responsabilidad política de la ciberseguridad (liderazgo de alto nivel, ministerios responsables, CNC).173

4. Comparativa internacional de indicadores tipo VAST

4.1. Marcos e índices nacionales relevantes

- NCSI (National Cyber Security Index) proporciona descripciones detalladas de indicadores de política, gobernanza, protección de infraestructuras, capacidades de respuesta, etc.; mide, por ejemplo, si existe liderazgo de alto nivel en ciberseguridad, estrategias nacionales, planes de acción y mecanismos de evaluación.3
- Dashboards nacionales: propuestas como la de Aspen Digital enfatizan cinco métricas nacionales: vulnerabilidades explotadas “antiguas”, número de incidentes significativos, tiempo medio de contención, pérdidas económicas totales y brecha de talento.4
- Programas de scoring como NIST CRS proporcionan una visión integrada y cuantitativa del riesgo en organizaciones federales, con métricas en tiempo real por sistemas y componentes, para priorizar acciones y autorizar sistemas.5

4.2. Tabla de contraste (visión país)

Eje	España (referencias actuales)	Enfoques internacionales (ejemplos)
Liderazgo y gobernanza	CNC como autoridad nacional, CCN-CERT y Plan Nacional de Ciberseguridad, inversión específica en ciber.161718	NCSI mide si hay liderazgo de alto nivel y estrategia nacional; muchos países definen “czar” o agencia central.3
Métricas de incidentes	Datos de volumen de incidentes (100.000 ataques en 2024; uno muy grave cada tres días).1617	Propuesta Aspen: número de incidentes significativos, MTTC, pérdidas a nivel país.4
Métricas de vulnerabilidades	No se publican de forma sistemática métricas como “% vulnerabilidades explotadas >1 año” a nivel país.	Aspen propone este indicador, y herramientas corporativas calculan ACR/VPR por activo.154
Cuantificación de riesgo	Se usan marcos NIS2/DORA y aproximaciones VaR en grandes empresas financieras.1512	NIST CRS y VaR se usan para cuantificar riesgo e informar decisiones de junta directiva.125
Cobertura de modelado de amenazas (VAST, etc.)	Muy heterogénea, concentrada en sectores avanzados (finanzas, tecnología, telco) y proyectos DevSecOps maduros.113	Países con fuerte cultura DevSecOps (EE. UU., nórdicos) usan VAST/STRIDE/PASTA en grandes organizaciones y comienzan a vincularlo a reporting sectorial.1137

5. Propuesta de indicadores VAST para una encuesta nacional en España

Aquí es donde entran las “viñetas amables” que piden a los encuestados algo más que un sí/no burocrático. La idea: traducir la lógica VAST (modelado sistemático de amenazas, automatización, integración y colaboración) a preguntas accionables para CISOs de organizaciones españolas críticas.

5.1. Bloque A – Cobertura de modelado de amenazas

Ejemplos de ítems (respuestas tipo escala Likert 1–5):

- “En su organización, los sistemas que soportan servicios esenciales (según NIS2) cuentan con un modelo de amenazas actualizado y revisado al menos una vez al año.”193
- “Las integraciones con terceros (proveedores cloud, SaaS, servicios gestionados) están cubiertas por modelos de amenazas operacionales que incluyen flujos de datos y supuestos de confianza.”21
- “La incorporación de nuevas APIs o microservicios requiere revisar y actualizar el modelo de amenazas antes de pasar a producción.”131

Indicadores derivados:

- % de organizaciones críticas con $\geq 80\%$ de sistemas clave cubiertos por modelos de amenazas formales.
- Índice de madurez de modelado de amenazas (0–5), basado en frecuencia de actualización, alcance y automatización.

5.2. Bloque B – Automatización, integración y colaboración (pilares VAST)

- “Disponemos de herramientas que generan o actualizan modelos de amenazas automáticamente a partir de arquitecturas o infraestructura como código.”⁸¹²
- “El modelado de amenazas está integrado en los pipelines CI/CD, de forma que cada cambio relevante en código o infraestructura se evalúa automáticamente.”⁷¹¹³
- “Los resultados del modelado de amenazas se comparten de forma comprensible con desarrollo, operaciones y negocio, y se usan para priorizar el backlog de seguridad.”⁶¹
- “Las decisiones de aceptación de riesgo basadas en amenazas se documentan y revisan periódicamente con la alta dirección.”¹²

Indicadores:

- % de organizaciones que integran el modelado de amenazas en CI/CD.
- % de organizaciones donde negocio participa en la priorización de amenazas.

5.3. Bloque C – Métricas de riesgo y eficacia

Preguntas posibles:

- “Calculamos regularmente la severidad de las amenazas abiertas usando criterios objetivos (por ejemplo, CVSS, VPR u otra métrica formal).”¹⁵¹⁰⁹
- “Medimos el tiempo que transcurre desde la identificación de una amenaza hasta la implantación del control mitigador acordado.”
- “Cuantificamos la exposición económica a ciber riesgos (por ejemplo, mediante escenarios VaR) y la comunicamos al consejo.”¹²

Indicadores:

- MTTR de mitigación de amenazas críticas.
- % de amenazas críticas con plazos de mitigación incumplidos.
- % de organizaciones que aplican métricas cuantitativas de riesgo (VaR, CRS, etc.).⁵¹²

5.4. Bloque D – Alineamiento con métricas nacionales e internacionales

Ejemplos:

- “Reportamos indicadores de ciberseguridad a organismos nacionales (CNC, CCN-CERT, supervisores sectoriales) en formatos estandarizados.”¹⁸¹⁷
- “Monitorizamos el número de incidentes significativos, el tiempo de contención y las pérdidas económicas derivadas de ciberincidentes.”¹⁶⁴
- “Revisamos periódicamente nuestra posición relativa frente a marcos e índices internacionales (NCSI, NIST CSF, etc.) para orientar inversiones.”¹⁹³

Indicadores:

- % de organizaciones críticas que miden y reportan “incidentes significativos” y MTTC.
- Grado de alineamiento percibido con marcos internacionales (escala 1-5).

6. Esbozo de “dashboard” VAST-nacional para España

Inspirándonos en las propuestas de NCSI, Aspen Digital y NIST CRS, un dashboard nacional alineado con VAST podría incluir:¹⁶¹⁷¹⁸

¹⁶ <https://ncsi.ega.ee/indicators/>

¹⁷ [https://csrc.nist.gov/CSRC/media/Presentations/nist-cyber-risk-scoring-crs-program-overview/images-media/NIST Cyber Risk Scoring \(CRS\) - Program Overview.pdf](https://csrc.nist.gov/CSRC/media/Presentations/nist-cyber-risk-scoring-crs-program-overview/images-media/NIST%20Cyber%20Risk%20Scoring%20(CRS)%20-%20Program%20Overview.pdf)

¹⁸ <https://www.aspendigital.org/blog/national-cyber-metrics/>

6. Cobertura de modelado de amenazas (VAST-like):
% de servicios esenciales con modelos de amenazas actualizados.
% de integraciones críticas con terceros modeladas.
 7. Riesgo técnico y explotación:
% de vulnerabilidades explotadas activamente con más de un año de antigüedad.4
Índice medio de severidad de amenazas por sector (basado en CVSS/VPR).1015
 8. Rendimiento de respuesta:
Número de incidentes significativos por trimestre, por sector.164
MTTC nacional (tiempo medio para contener actividad maliciosa).4
 9. Impacto económico y talento:
Estimación de pérdidas económicas anuales por ciberincidentes.4
% de puestos de ciber sin cubrir en sectores críticos.21204
 10. Gobernanza y cumplimiento:
Grado de implementación del Plan Nacional de Ciberseguridad (acciones completadas vs. plan).163
Nivel de cumplimiento de NIS2/DORA reportado por sectores regulados.19
- % de servicios esenciales con modelos de amenazas actualizados.
 - % de integraciones críticas con terceros modeladas.
 - % de vulnerabilidades explotadas activamente con más de un año de antigüedad.4
 - Índice medio de severidad de amenazas por sector (basado en CVSS/VPR).1015
 - Número de incidentes significativos por trimestre, por sector.164
 - MTTC nacional (tiempo medio para contener actividad maliciosa).4
 - Estimación de pérdidas económicas anuales por ciberincidentes.4
 - % de puestos de ciber sin cubrir en sectores críticos.21204
 - Grado de implementación del Plan Nacional de Ciberseguridad (acciones completadas vs. plan).163
 - Nivel de cumplimiento de NIS2/DORA reportado por sectores regulados.19

Cada bloque podría alimentarse, de forma más o menos directa, de programas de modelado de amenazas VAST desplegados en operadores críticos, de forma que el país no solo cuenta incidentes ex post, sino que monitoriza las “amenazas diseñadas” ex ante.

2223242526272829303132333435363738394041424344